KAPASA MAKASA UNIVERSITY

SCHOOL OF APPLIED SCIENCE AND OPEN LEARNING

DEPARTMENT OF INFORMATION AND COMMUNICATION TECHNOLOGY

BACHELOR OF SCIENCE IN CYBER SECURITY

COURSE CODE: CYS460

COURSE TITLE: **SECURITY AND RISK MANAGEMENT PRACTICES**

END OF TERM3 TEST 1&2

DATE: 7th OCTOBER, 2026 TIME: 14: OO-16:00 HOURS

DURATION:2 HOURS

INSTRUCTIONS

1. Write your **Student Identification Number** on the Answer Booklet provided
2. Question ONE (1) is compulsory
3. Choose any TWO (2) questions from the remaining questions.
4. Each Question carries 25marks

CamScanner

QUESTION ONE

The KMU CICT Department has authorised a security investigation of a designated computer connected to the departmental network. The purpose of the investigation is to identify exposed network services, determine possible security weaknesses and produce recommendations for improving the security of the system.

As part of the investigation, a cybersecurity investigator performed an Nmap scan from the Windows Command Prompt. The following is the captured output:

```
C:\Users\ICT-LAB>nmap -sV -O 192.168.8.100

Starting Nmap 7.98 ( https://nmap.org )
Nmap scan report for 192.168.8.100
Host is up (0.0031s latency).
Not shown: 997 closed tcp ports

PORT    STATE SERVICE       VERSION
135/tcp open  msrpc         Microsoft Windows RPC
139/tcp open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp open  Microsoft-ds  Windows Server 2019 - 2022 Microsoft-ds

MAC Address: 00:1A:2B:3C:4D:5E (Dell Inc.)

Device type: general purpose
Running: Microsoft Windows
OS CPE: cpe:/o: Microsoft: windows
OS details: Microsoft Windows 10/11

Network Distance: 1 hop

Service Info: Host: KMU-CICT-PC01

Nmap done: 1 IP address (1 host up) scanned in 12.45 seconds
```

a) From the Nmap output, identify:[5]

i. The IP address of the computer investigated.
ii. Whether the host is active.
iii. The number of open TCP ports shown.
iv. The three open ports and the services associated with them.

b) Analyse the significance of ports 135, 139 and 445 being open on the computer. Explain what security concerns may arise from exposing these services on a departmental network.[6]

c) From the output, identify the likely operating system and explain why OS identification is useful during a cybersecurity investigation.[3]

d) Identify TWO security weaknesses or risks that could be investigated further based on the Nmap results. For each risk, recommend an appropriate security control.[6]

e) Based on the evidence provided, prepare a brief conclusion for the KMU CICT Department stating whether the computer requires further security investigation. Give TWO reasons to support your conclusion.[5]

QUESTION TWO

The Zambia Police Service Cyber and Digital Forensics Laboratory receives a number of digital devices associated with a suspected cybercrime investigation. The devices may contain electronic evidence such as documents, photographs, communication records, browser information and other digital artefacts.

The laboratory must ensure that digital evidence is properly identified, acquired, preserved, analysed and documented. A failure to maintain evidence integrity could affect an investigation and the ability to present reliable evidence in court.

a) Analyse FOUR assets, FOUR vulnerabilities and FOUR corresponding threats that could affect the security of digital evidence in the laboratory.[12]

b) Analyse how ANY TWO of the identified vulnerabilities could increase the likelihood of successful compromise, alteration or loss of digital evidence.[4]

c) Evaluate the possible operational, legal and information-security consequences of compromised digital evidence. [6]

d) Identify the highest-priority risk from your analysis and justify why it should receive immediate attention.[3]

QUESTION THREE

ZICTA/ZmCIRT, a financial institution and a telecommunications organisation are assessing cybersecurity risks affecting their information systems. A risk team uses a 5 × 5 risk matrix.

The following risks have been identified:

Risk	Likelihood	Impact
Phishing attack Medium	4 (12)	3
Unauthorised system access high	3 (15)	5
Malware infection high	4 (16)	4
Customer-data leakage high	3 (15)	5
Network service disruption low	2 (8)	4

a) Calculate the risk score for each of the five risks.[5]

b) Rank the risks from highest to lowest priority based on their risk scores.[5]

c) Select the TWO highest-scoring risks and analyse how each could affect the confidentiality, integrity and availability of organisational information and services. [6]

d) For each of the two highest-priority risks, recommend TWO appropriate controls and explain how each control reduces the risk.[6]

e) Explain why an organisation should continue monitoring a risk even after implementing controls.[3]

0-9 low 10-14 Medium 15-17 High 18-20 Critical

CamScanner

QUESTION FOUR

Digital Safe is conducting cybersecurity activities involving students and organisations in Zambia. During a cybersecurity assessment, a participating organisation discovers that several employees use weak passwords, some systems have outdated software, and users frequently respond to suspicious emails.

The organisation wants to conduct a formal risk assessment before deciding which security controls should receive priority.

a) Construct a risk-assessment entry for the organisation by identifying the following: [6]

- Asset
- Threat
- Vulnerability
- Consequence
- Likelihood
- Impact

b) Assume that the likelihood of the identified risk is 4 and its impact is 4. Calculate the inherent risk score and explain what the score represents.[4]

c) Design THREE security controls that could be implemented to reduce the identified risk. For each control, state whether it primarily reduces likelihood, impact, or both.[6]

d) After implementing the controls, the likelihood is reduced from 4 to 2, while the impact remains 4.

Calculate the residual risk and evaluate whether the controls have improved the organisation's risk position.[5]

e) Create a simple risk-monitoring plan containing THREE activities that the organisation should perform after implementing the controls.[4]

-END OF TEST-